Unauthenticated Server-Side Request Forgery via Incomplete Fix

Heimdall | CWE-918 (SSRF guard added only to ItemController; SupportedApps sink unguarded)

Vulnerability Name	Unauthenticated SSRF via the test_config / livestats path (SafeUrlFetcher guard not applied to SupportedApps::execute)
Researcher	Kashish Topiwala
Severity	High
CVSS v3.1 Base Score	7.5
CVSS v3.1 Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CWE	CWE-918: Server-Side Request Forgery
Affected Product	Heimdall (linuxserver/Heimdall)
Affected Version	current (tested at commit 9ad5864)
Affected Component	POST /test_config (and GET /get_stats) -> SupportedApps::execute()
Attacker Profile	Unauthenticated (default passwordless install; endpoints are CSRF-exempt)

Description

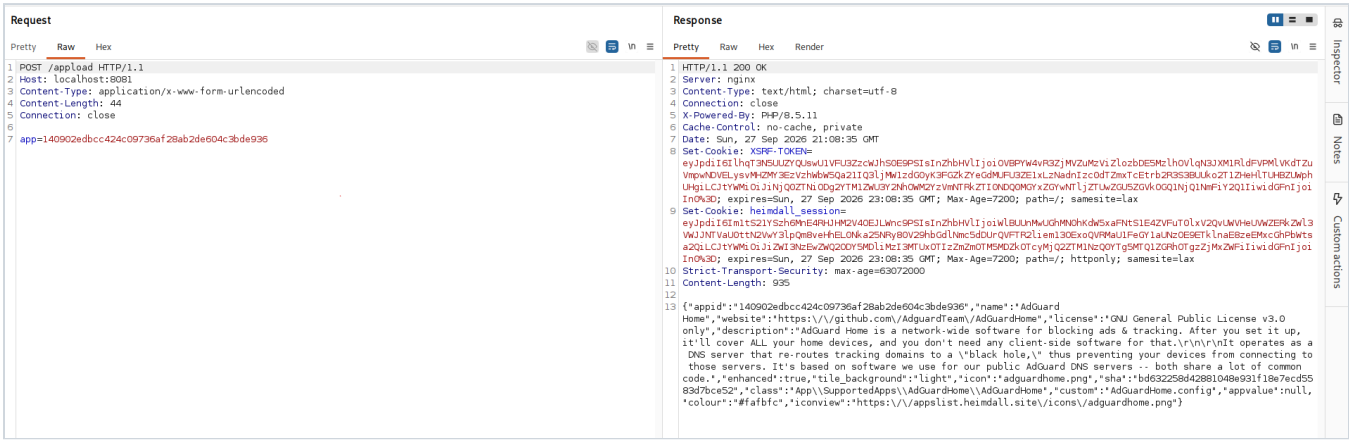
An unauthenticated attacker can make the Heimdall server issue HTTP requests to arbitrary internal and external hosts and ports (including the cloud metadata IP), and read a status/port oracle plus partial response data. Heimdall recently added a SafeUrlFetcher SSRF guard, but only to ItemController; the enhanced-app test/live-stats requests go through SupportedApps::execute(), a raw Guzzle client with no validation.

Affected Files

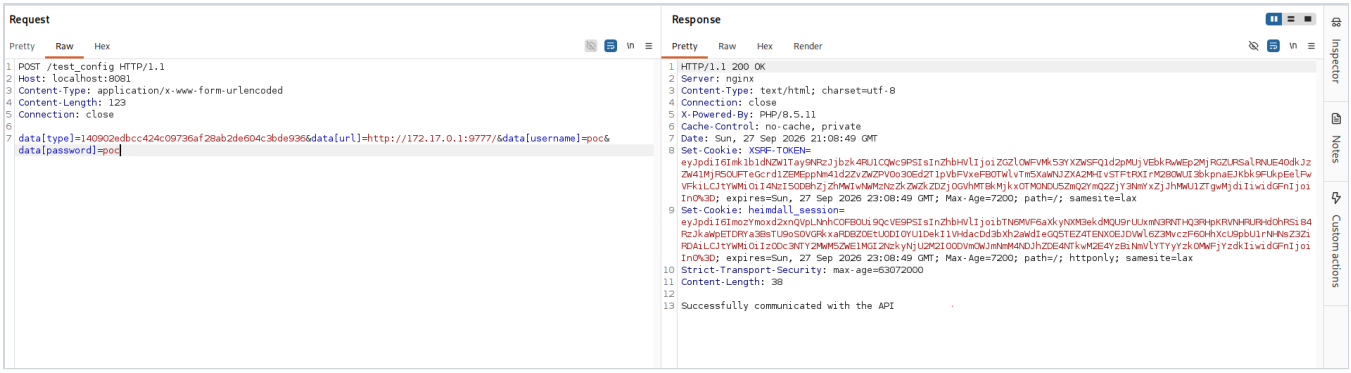
- Unguarded sink (raw Guzzle, no SSRF validation): app/SupportedApps.php (execute())
- Reachable unauthenticated, CSRF-exempt: routes/web.php (POST test_config), bootstrap/app.php (CSRF except list), CheckAllowed.php (passwordless default = no auth)
- Entry: ItemController.php testConfig() builds the request from attacker data[url]; contrast the guarded execute() in the same controller that uses SafeUrlFetcher

Steps to Reproduce

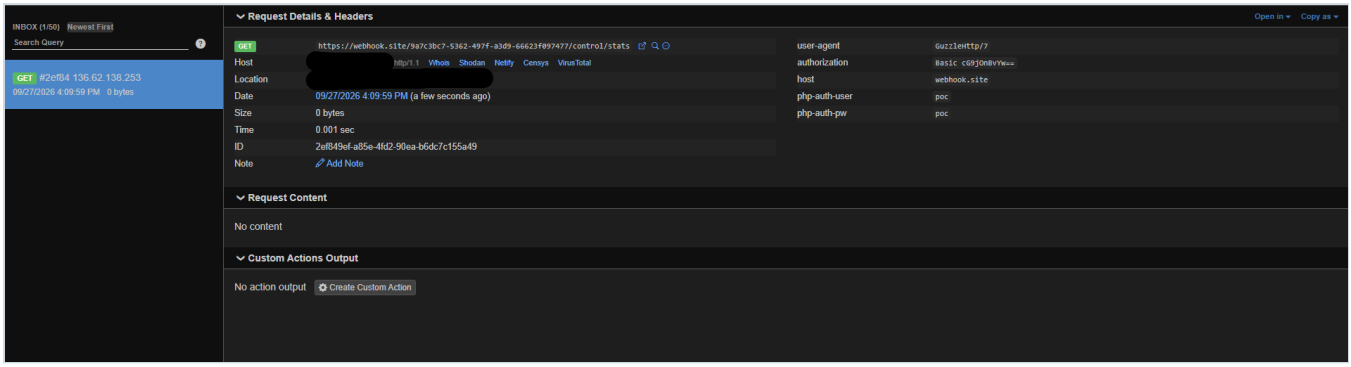
Step 1: Unauthenticated POST /appload installs an enhanced application class (no login, no CSRF token required).



Step 2: Unauthenticated POST /test_config with an attacker-chosen data[url] makes the Heimdall server fetch that internal target; the response body is a status oracle ('Successfully communicated with the API').



Step 3: Out-of-band confirmation. Pointing data[url] at an attacker-controlled collector shows the Heimdall server itself issuing the request (User-Agent GuzzleHttp/7, the server's egress IP, and the injected path and basic-auth), proving full SSRF to arbitrary external and internal hosts. The cloud-metadata IP 169.254.169.254 is also reachable on this path (the guarded ItemController path blocks it).



Impact

- An unauthenticated attacker forces the server to make requests to arbitrary internal and external hosts/ports it should not reach.
- The response is a status/port oracle (and partial reflected data via get_stats), enabling internal network mapping and service discovery.
- The cloud-metadata IP 169.254.169.254 is reachable on this path (the guarded ItemController path blocks it), exposing cloud deployments.
- No authentication is required on a default passwordless install, and the endpoints are CSRF-exempt and not rate-limited.

Remediation

- Route SupportedApps::execute() (and all enhanced-app HTTP requests) through the same SafeUrlFetcher SSRF guard used by ItemController.
- Require authentication for test_config / get_stats / appload, and add them to CSRF protection and rate limiting.
- Deny redirects and validate the resolved IP at request time.

References

- https://cwe.mitre.org/data/definitions/918.html
- https://owasp.org/www-community/attacks/Server_Side_Request_Forgery
- https://portswigger.net/web-security/ssrf